HTB SHERLOCK

Unit42

Category	DFIR, Windows Sysmon log analysis
Difficulty	Very Easy
Artifacts	`Microsoft-Windows-Sysmon-Operational.evtx`
Tools	`evtx_dump`, `jq`, `grep`, `sort`, `uniq`
Author	M3RICK

1 Summary

A Windows workstation (`DESKTOP-887GK2L`, user `CyberJunkie`) was infected by a malicious executable downloaded from Dropbox with Firefox. The file, `Preventivo24.02.14.exe.exe`, uses a double extension and an Italian lure name ("preventivo" means "quote"). Once executed, it checked internet connectivity against `www.example.com`, extracted an MSI package, backdated the creation time of the files it wrote (time stomping), and had `msiexec` install a backdoored UltraVNC under `C:\Games\`. It then deleted its staging files and terminated, about two seconds after starting.

The Sherlock is based on Palo Alto Unit 42 research on a campaign distributing a backdoored UltraVNC. The analysis relies exclusively on a single Sysmon event log.

Item	Finding
Malicious file	`C:\Users\CyberJunkie\Downloads\Preventivo24.02.14.exe.exe`
SHA256	`0CB44C4F8273750FA40497FCA81E850F` `73927E70B13C8F80CDCFEE9D1478E6F3`
Delivery	Dropbox download through Firefox
Connectivity check	`www.example.com` (93.184.216.34), TCP 80
Payload	Backdoored UltraVNC installed by `msiexec` in `C:\Games\`
Defense evasion	Double extension, time stomping, staging file deletion
Execution window	03:41:56 to 03:41:58 UTC, 2024-02-14

2 Artifact Preparation

The archive contains a single Sysmon log. EVTX is a binary format; the useful fields of Sysmon events (`Image`, `TargetFilename`, `QueryName` …) are stored in the `EventData` section. The log was converted to JSON Lines with `evtx_dump` (from the Rust `evtx` crate), one event per line, then queried with `jq`:

```
$ cargo install evtx
$ evtx_dump -o jsonl Microsoft-Windows-Sysmon-Operational.evtx > sysmon.jsonl
$ wc -l sysmon.jsonl
169 sysmon.jsonl
```

The event identifier is located at `.Event.System.EventID` and is stored as a number. Every query in this analysis follows the same pattern: filter on the event identifier with `select`, then extract fields:

```
jq -r 'select(.Event.System.EventID == N) | [.Event.EventData.Field1, ...] | @tsv' sysmon.jsonl
```

3 Analysis

3.1 Event Overview

The first step on any event log is the distribution of event identifiers, which maps the available evidence:

```
$ jq '.Event.System.EventID' sysmon.jsonl | sort -n | uniq -c
      6 1       Process creation
     16 2       File creation time changed
      1 3       Network connection
      1 5       Process terminated
     15 7       Image loaded
      1 10      Process access
     56 11      File created
     14 12      Registry object created/deleted
     19 13      Registry value set
      2 15      File stream created
      7 17      Pipe created
      3 22      DNS query
     26 23      File deleted
      2 26      File delete logged
```

The log contains 56 file creation events (ID 11).

> **Pitfall.** Counting with `jq ... | wc -l` initially returned 2856. Without `-c`, `jq` pretty-prints each object over about fifty lines, so `wc -l` counted lines of output, not events. `jq -c` (one object per line) or counting inside `jq` with `jq -s '[ .[] | select(...) ] | length'` gives the correct result.

3.2 Identification of the Malicious Process

Process creation events (ID 1) list every program executed:

```
$ jq -r 'select(.Event.System.EventID == 1) | [.Event.EventData.UtcTime,
    .Event.EventData.Image, .Event.EventData.ParentImage] | @tsv' sysmon.jsonl
03:41:45.304  ...\Mozilla Firefox\pingsender.exe            ...\Mozilla Firefox\firefox.exe
03:41:56.538  C:\Users\CyberJunkie\Downloads\Preventivo24.02.14.exe.exe
                                                           C:\Windows\explorer.exe
03:41:57.604  C:\Windows\System32\msiexec.exe              C:\Windows\System32\services.exe
03:41:57.787  C:\Windows\SysWOW64\msiexec.exe              C:\Windows\System32\msiexec.exe
03:41:57.905  C:\Windows\SysWOW64\msiexec.exe              ...\Preventivo24.02.14.exe.exe
03:41:58.178  C:\Windows\SysWOW64\msiexec.exe              C:\Windows\System32\msiexec.exe
```

`Preventivo24.02.14.exe.exe` stands out on three points:

- **Double extension.** Windows hides known extensions by default, so the user sees `Preventivo24.02.14.exe`, which looks like a dated document (MITRE T1036.007).
- **Location.** It runs from `Downloads`, and its parent is `explorer.exe`: the user double-clicked a downloaded file (T1204.002).
- **Lure.** “Preventivo” is Italian for “quote”, a common business phishing theme.

The process ran as `DESKTOP-887GK2L\CyberJunkie` with Medium integrity. Its own image load event (ID 7) reports it as unsigned (`Signed: false`), and its loading of `mscoree.dll` indicates a .NET component.

The `msiexec` processes appear legitimate at first sight, as they run from `System32` and `SysWOW64`. Their `ParentImage` and `CommandLine` show otherwise: one of them is launched directly by the malicious file to install an MSI it has just written:

```
"C:\Windows\system32\msiexec.exe" /i "C:\Users\CyberJunkie\AppData\Roaming\
  Photo and Fax Vn\Photo and vn 1.1.2\install\F97891C\main1.msi"
  AI_SETUPEXEPATH=C:\Users\CyberJunkie\Downloads\Preventivo24.02.14.exe.exe ...
```

The `AI_` properties are characteristic of Advanced Installer packages. The malware is a wrapper that abuses a trusted system binary to perform the installation (T1218.007, System Binary Proxy Execution: Msiexec).

3.3 Delivery

DNS queries (ID 22) show which process resolved which domain:

```
$ jq -r 'select(.Event.System.EventID == 22) | [.Event.EventData.Image,
    .Event.EventData.QueryName] | @tsv' sysmon.jsonl
...\Mozilla Firefox\firefox.exe
uc2f030016253ec53f4953980a4e.dl.dropboxusercontent.com
...\Mozilla Firefox\firefox.exe               d.dropbox.com
...\Downloads\Preventivo24.02.14.exe.exe      www.example.com
```

`dl.dropboxusercontent.com` is the domain Dropbox uses to serve direct file downloads. The download is confirmed by two independent sources:

- **File creation (ID 11).** Firefox writes `skZdsnwf.exe.part` in `Downloads`, then `Preventivo24.02.14.exe.exe` at 03:41:26, one second after resolving the Dropbox domain.
- **Mark of the Web (ID 15).** Firefox attached a `Zone.Identifier` alternate data stream to the file, recording its origin:

```
$ jq -r 'select(.Event.System.EventID == 15) | .Event.EventData.Contents' sysmon.jsonl
[ZoneTransfer]  ZoneId=3  ReferrerUrl=https://www.dropbox.com/
HostUrl=https://uc2f030016253ec53f4953980a4e.dl.dropboxusercontent.com/cd/0/get/...
```

`ZoneId=3` is the Internet zone. Hosting the payload on a legitimate cloud service lets the download pass reputation-based filtering (T1105, Ingress Tool Transfer; delivery from a trusted cloud service).

3.4 Connectivity Check

The malicious process resolved `www.example.com`, then opened its only network connection (ID 3):

```
$ jq -r 'select(.Event.System.EventID == 3) |
[.Event.EventData.Image, .Event.EventData.Protocol,
    .Event.EventData.DestinationIp, .Event.EventData.DestinationPort] | @tsv' sysmon.jsonl
...\Downloads\Preventivo24.02.14.exe.exe    tcp    93.184.216.34    80
```

The DNS answer (`QueryResults: ::ffff:93.184.216.34`) shows that this IP is the address of `www.example.com` at the time. It is not a command and control server: `example.com` is a domain reserved for documentation, always reachable, and used here to test internet access before proceeding (T1016.001, Internet Connection Discovery). Reporting this address as C2 infrastructure would lead to blocking a benign domain while missing the actual operator access, which is provided by the VNC backdoor.

3.5 Time Stomping

Event ID 2 is logged when a process changes the creation time of a file. Sysmon records the new value (`CreationUtcTime`) and the real value (`PreviousCreationUtcTime`):

```
$ jq -r 'select(.Event.System.EventID == 2) | [.Event.EventData.TargetFilename,
    .Event.EventData.CreationUtcTime, .Event.EventData.PreviousCreationUtcTime] | @tsv'
sysmon.jsonl
...\F97891C\main1.msi                       2024-01-14 08:14:23.713   2024-02-14 03:41:57.545
...\WindowsVolume\Games\powercfg.msi        2024-01-10 18:12:27.357   2024-02-14 03:41:58.389
...\WindowsVolume\Games\once.cmd            2024-01-10 18:12:26.458   2024-02-14 03:41:58.404
...\WindowsVolume\Games\UltraVNC.ini        2024-01-10 18:12:26.530   2024-02-14 03:41:58.404
...\TempFolder\~.pdf                        2024-01-14 08:10:06.029   2024-02-14 03:41:58.404
```

```
...\WindowsVolume\Games\viewer.exe          2024-01-10 18:12:26.670   2024-02-14 03:41:58.420
...\WindowsVolume\Games\vnchooks.dll        2024-01-10 18:12:26.686   2024-02-14 03:41:58.420
...
```

All 16 events originate from `Preventivo24.02.14.exe.exe`. Creation dates are moved back by one month, to 2024-01-10 and 2024-01-14, so that an analyst filtering for files created on the day of the incident does not see them (T1070.006, Timestomp). The PDF creation time was set to **2024-01-14 08:10:06**.

The pattern of the forged values is itself informative: the sub-second offsets between files (26.295, 26.326, 26.373…) look like the timestamps of the files on the attacker's build machine, preserved by the installer, rather than arbitrary values.

> **Detection.** Time stomping only changes the `$STANDARD_INFORMATION` timestamps. On a disk image, the `$FILE_NAME` attribute of the MFT would still hold the real creation time; Sysmon ID 2 records the change directly.

3.6 Dropped Files

File creation events (ID 11) show the files written by the malicious process and by `msiexec`:

```
$ jq -r 'select(.Event.System.EventID == 11) | [.Event.EventData.Image,
    .Event.EventData.TargetFilename] | @tsv' sysmon.jsonl | grep -i once.cmd
...\Preventivo24.02.14.exe.exe  C:\Users\CyberJunkie\AppData\Roaming\Photo and Fax Vn\
                                Photo and vn 1.1.2\install\F97891C\WindowsVolume\Games\once.cmd
C:\Windows\system32\msiexec.exe C:\Games\once.cmd
```

The same file appears twice, which reveals the two-stage installation:

1. The malicious process extracts the package into a staging directory named after a fake software product, `AppData\Roaming\Photo and Fax Vn\Photo and vn 1.1.2\install\F97891C\`. `WindowsVolume\Games\` mirrors the target layout of the MSI.
2. `msiexec` installs the files to their final location, `C:\Games\`: `on.cmd`, `c.cmd`, `cmmc.cmd`, `once.cmd`, `viewer.exe`, `taskhost.exe`.

The staged files include `UltraVNC.ini`, `vnchooks.dll`, `ddengine.dll` and the `UVncVirtualDisplay` driver, which are UltraVNC components. `viewer.exe` and `taskhost.exe` are the VNC binaries; naming one of them `taskhost.exe` after a legitimate Windows process is masquerading (T1036.005). The `.cmd` scripts are batch launchers whose content is not available in the log.

3.7 Cleanup and Termination

File deletion events (ID 23 and 26) show that the malicious process removed its whole staging directory, including `main1.msi`, the `.cmd` scripts, the DLLs and the PDF decoy, once `msiexec` had installed the payload (T1070.004, File Deletion). Only the copy under `C:\Games\` remains.

The process then terminated itself (ID 5):

```
$ jq -r 'select(.Event.System.EventID == 5) | [.Event.EventData.Image,
    .Event.EventData.UtcTime] | @tsv' sysmon.jsonl
C:\Users\CyberJunkie\Downloads\Preventivo24.02.14.exe.exe    2024-02-14 03:41:58.795
```

The whole infection, from execution to termination, took 2.3 seconds.

3.8 Additional Observations

Scheduled task capability. The malicious process loaded `taskschd.dll`, the Task Scheduler library. This suggests persistence through a scheduled task, but the log contains no event proving that a task was created; confirming it would require the `Microsoft-Windows-TaskScheduler/Operational` log or Security event 4698.

Persistence and the VNC backdoor were not observed running. No process creation is logged for `C:\Games\viewer.exe` or `taskhost.exe`, and no network connection other than the connectivity check. The backdoor was installed but not observed executing within the log's timeframe.

Log collection. The last event is `mmc.exe` writing `Microsoft-Windows-Sysmon-Operational.evtx` to the user's desktop at 03:43:26: the log export performed for the investigation.

4 Timeline

All times are UTC on 2024-02-14.

Time	Event ID	Event
03:41:25	22	Firefox resolves `uc2f030016253ec53f4953980a4e.dl.dropboxusercontent.com`
03:41:26	11	Firefox writes `Preventivo24.02.14.exe.exe` to `Downloads`
03:41:30	15	`Zone.Identifier` stream written (Mark of the Web, Dropbox origin)
03:41:56	1	User executes `Preventivo24.02.14.exe.exe` from Explorer
03:41:56	22	DNS query for `www.example.com`
03:41:57	3	TCP connection to 93.184.216.34:80 (connectivity check)
03:41:57	2	`main1.msi` written and timestomped
03:41:57	1	`msiexec /i main1.msi` launched by the malicious process
03:41:58	2, 11	UltraVNC components and `.cmd` scripts staged and timestomped
03:41:58	11	`msiexec` installs the payload in `C:\Games\`
03:41:58	23, 26	Staging files deleted
03:41:58	5	Malicious process terminates
03:43:26	11	Sysmon log exported by the analyst

5 MITRE ATT&CK Mapping

Technique	ID	Evidence
Ingress Tool Transfer	T1105	Download from `dl.dropboxusercontent.com`
User Execution: Malicious File	T1204.002	Parent `explorer.exe`, file in `Downloads`
Masquerading: Double File Extension	T1036.007	`.exe.exe`
Masquerading: Match Legitimate Name	T1036.005	`C:\Games\taskhost.exe`
Internet Connection Discovery	T1016.001	`www.example.com`, 93.184.216.34:80
System Binary Proxy Execution: Msiexec	T1218.007	`msiexec /i main1.msi`

Indicator Removal: Timestomp	T1070.006	16 events ID 2
Indicator Removal: File Deletion	T1070.004	Staging directory deleted
Remote Access Software	T1219	Backdoored UltraVNC installed

6 Task Answers

Task	Question	Answer
1	Number of events with ID 11	56
2	Malicious process	`C:\Users\CyberJunkie\Downloads\Preventivo24.02.14.exe.exe`
3	Cloud drive used for distribution	Dropbox
4	Timestomped creation time of the PDF	2024-01-14 08:10:06
5	Location of `once.cmd`	`C:\Users\CyberJunkie\AppData\Roaming\Photo and Fax Vn\Photo and vn 1.1.2\install\F97891C\WindowsVolume\Games\once.cmd`
6	Dummy domain contacted	`www.example.com`
7	IP address contacted	`93.184.216.34`
8	Process termination time	2024-02-14 03:41:58

7 Indicators of Compromise

Type	Value
SHA256	`0CB44C4F8273750FA40497FCA81E850F73927E70B13C8F80CDCFEE9D1478E6F3`
SHA1	`18A24AA0AC052D31FC5B56F5C0187041174FFC61`
MD5	`32F35B78A3DC5949CE3C99F2981DEF6B`
File name	`Preventivo24.02.14.exe.exe`
Directory	`%APPDATA%\Photo and Fax Vn\`
Directory	`C:\Games\`
Domain	`uc2f030016253ec53f4953980a4e.dl.dropboxusercontent.com`

`www.example.com` and 93.184.216.34 are deliberately excluded: they are benign and would only generate false positives.

8 Recommendations

Containment

- Isolate the host, and remove `C:\Games\` and any service, scheduled task or Run key pointing to it.
- Check the Task Scheduler log and the registry for persistence pointing to the UltraVNC binaries.

- Search the network for other hosts with the file hash or a `C:\Games\` directory.

Hardening

- Enable “show file extensions” through Group Policy, which defeats the double extension.
- Restrict execution from user-writable paths (`Downloads`, `%APPDATA%`) with AppLocker or WDAC.
- Block or alert on unapproved remote access software such as VNC.

Monitoring

- Alert on Sysmon ID 2 (time stomping is rarely legitimate outside installers), on `msiexec /i` launched by a process in a user directory, and on executables with a double extension.

9 Lessons Learned

- `wc -l` counts lines, not records. With structured data, count inside the tool that understands the structure (`jq ... | length`), or force one record per line (`jq -c`).
- A process running from `System32` is not automatically legitimate. `ParentImage` and `CommandLine` revealed that `msiexec` was driven by the malware.
- The only IP contacted was not a C2 server. Checking what the address resolves to before labelling it avoids a wrong IOC.
- A file can appear in several events with different paths: the staging path and the final path tell two parts of the same story.

9.1 Relation to evtx_timeline

evtx_timeline currently normalises the `System` section of each event. This challenge shows that for Sysmon, the evidence lives in `EventData`. Extracting `Image`, `ParentImage`, `TargetFilename` and `QueryName` would allow new rules, for example an alert on event ID 2 or on a process executed from `Downloads` with a double extension.